

DEFENSE COMPARISON REPORT

The Grand Marina Hotel: HYDROLOGIC Water Monitoring System

Prepared for: Marcus Webb, General Manager, The Grand Marina Hotel

Prepared by: Joarder Rashid, Security Intern, Hydroficient

Date: April 14, 2026

1. EXECUTIVE SUMMARY

Our testing showed that the HYDROLOGIC water monitoring system at The Grand Marina would accept replayed messages. This means an attacker could record a real sensor reading and send it again later, and the system would treat it as a fresh legitimate reading. We ran 12 experiments testing three different protections on their own and all together. The results were clear: only when all three protections were running at the same time did the system block every type of attack. We recommend turning on all three protections right away. The extra processing they require is less than one millisecond per reading, which will have zero effect on hotel operations.

2. THE PROBLEM

Think of it like someone recording a garage door opener signal and playing it back later. The garage opens because the signal is real, it just is not new. Our water monitoring system had the exact same problem. Even though we already have encryption and device verification in place, the system had no way to tell whether a reading was sent just now or was a recording from an hour ago. Anyone who captured a real message could send it again and the system would accept it without any question.

What could go wrong at The Grand Marina:

- The phantom shutoff. Imagine an attacker replays a recorded maintenance command from an earlier test that shut off the water supply to the main building. The system would carry out that command again at 2 AM, cutting water to guests with no warning and no legitimate reason for doing so.
- The hidden leak. If a pipe in the pool wing starts leaking and pressure begins to drop, an attacker could replay an older reading that showed normal pressure. The dashboard would show everything as fine while real water damage was happening behind the scenes.
- The false billing event. An attacker could replay a high-usage reading from a busy weekend, causing the system to log it again as a new event. This would inflate usage records and could trigger false overage charges, which is exactly the kind of data integrity problem an insurance auditor looks for.

3. DEFENSES TESTED

We tested three different protections. Each one is designed to catch a different kind of attack:

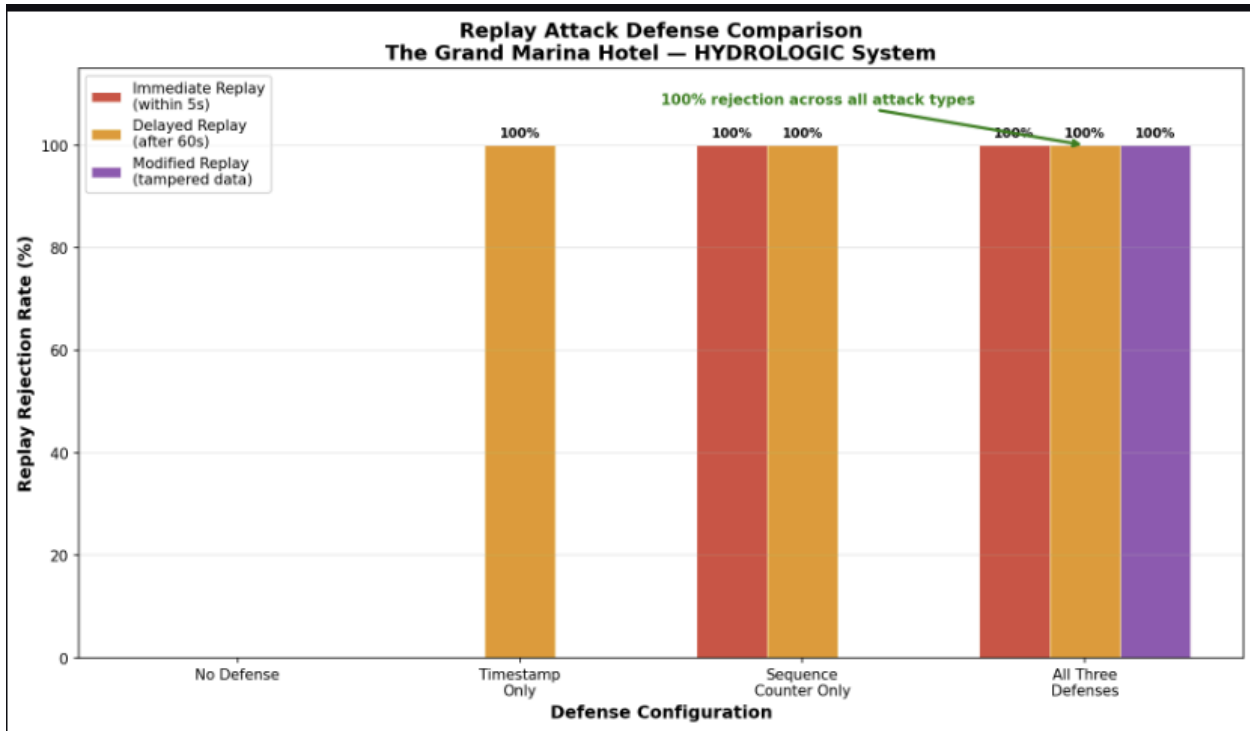
- Message freshness check: Each sensor reading carries a time stamp. If the reading is older than 30 seconds when it arrives, the system rejects it automatically. Think of it like a parking ticket that is only valid for a limited time and then expires.

- Message numbering: Each reading gets a unique number that can only be used once, like a concert ticket. If the system sees the same number twice, it knows the second one is a replay and rejects it right away.
- Message signing: Each reading carries a tamper-evident seal, like a wax seal on an envelope. If anyone changes the contents of the message after it was sent, even changing a single digit in a pressure reading, the seal breaks and the system rejects it.

4. TESTING RESULTS

We ran 12 controlled experiments testing four protection setups against three types of replay attack. The table below shows the percentage of attacks each setup successfully blocked.

Protection Setup	Immediate Replay	Delayed Replay	Tampered Replay
No protection	0%	0%	0%
Freshness check only	0%	100%	0%
Message numbering only	100%	100%	0%
All three combined	100%	100%	100%



Key finding: No single protection on its own covered every attack type. The freshness check missed fast replays because those messages were still within the 30-second window. Message numbering missed tampered messages because the attacker gave the modified reading a new, unused number. Only when all three protections ran together did the system block 100% of attacks in every category.

5. RECOMMENDATION

We recommend turning on all three message protections across every HYDROLOGIC device at The Grand Marina as soon as possible.

Why all three:

- Complete coverage. Each protection on its own has a gap. Together they cover every attack type we tested: immediate replays, delayed replays, and tampered messages. All 12 of our experiments showed 100% of attacks blocked when all three were running together.
- No impact on hotel operations. All three checks together take less than one millisecond per sensor reading. Since the HYDROLOGIC devices send readings every 5 seconds, this added time is completely invisible. Staff, the dashboard, and leak detection alerts will notice absolutely no difference.
- Already built and tested. The protected system is not a future plan. It is already built, tested, and ready to go today. Turning it on just means replacing the current monitoring scripts with the defended versions that passed all 12 of our experiments with perfect scores.

6. NEXT STEPS

- Turn on the defended monitoring scripts across all three HYDROLOGIC devices in the main building, pool and spa wing, and kitchen and laundry areas.
- Set up alerts for rejected messages. If the system starts blocking an unusual number of readings, that could be a sign that someone is actively trying to attack the system, and the IT team should be told right away.
- Build a simple security dashboard so hotel staff can see at a glance which devices are working normally and whether any messages are being rejected, without having to dig through technical logs.

7. INDUSTRY REFERENCES

The protections we built are not something we invented from scratch. They match what the industry already recommends:

- AWS IoT Core, the platform that powers connected device systems for thousands of companies, uses message deduplication to prevent replays. This is the same concept as our message numbering protection.
- IEC 62443, the international security standard for connected industrial systems, requires message integrity verification for devices like the HYDROLOGIC sensors. Our message signing and freshness checks satisfy this requirement, which auditors are increasingly looking for.
- MQTT version 5, the latest version of the communication protocol the HYDROLOGIC system uses, added a built-in message expiry feature. Publishers can set how long a message stays valid and the system discards expired ones automatically. Our freshness check works on the same principle.

These references show that what we built follows established industry practice. The Grand Marina is not doing anything unusual by adopting these protections. It is catching up to what the industry already considers standard for connected sensor systems.